

PENETRATION TESTING REPORT

Mediroza General Hospital
<https://medirozahospital.com>

Attribute	Details
Client	Mediroza General Hospital
Engagement Type	Black-box Penetration Test & Vulnerability Assessment
Target	https://medirozahospital.com
Duration	3 Days Batch B082 Week 4
Report Date	06 September 2026
Overall Risk	CRITICAL
Classification	CONFIDENTIAL — Authorised Personnel Only
Prepared For	Networkwalks Educational Engagement

Public-Safe Submission Note

This version is professionally formatted for submission and deliberately redacts patient records, personal identifiers, recovered passwords and raw database contents. Detailed confidential evidence should remain in the authorised assessment evidence set.

Author / Pentester: _____

Program: Cybersecurity | Networkwalks | Batch B082

1. Executive Summary

A black-box penetration test was conducted against the Mediroza General Hospital web application in a controlled educational environment with explicit written authorisation. The objective was to identify vulnerabilities, demonstrate controlled real-world impact and provide actionable remediation guidance.

All four Week 4 milestones were completed. The assessment demonstrated a chained confidentiality risk: SQL injection enabled authentication bypass; three restricted patient laboratory reports were retrieved; weak PDF passwords were recovered; and a public historical database backup exposed staff and shareholder information.

Overall Organisational Risk: CRITICAL

Key Findings

Finding	Severity	Primary Impact
SQL Injection — Patient Portal Authentication Bypass	Critical	Unauthorised access to patient reports
Weak PDF Encryption Passwords	High	Protected medical information recoverable
Sensitive Database Backup Exposure	Critical	Staff and shareholder information exposed
Directory Listing — /old/	High	Sensitive historical resources discoverable
Sensitive PDF Metadata	Medium	Internal operational information disclosed

2. Scope & Methodology

2.1 Engagement Scope

Testing was limited to the authorised target domain and its associated web application components. The assessment was performed from an external, unauthenticated perspective without internal network access or staff credentials.

In Scope

- Public web application and patient portal
- Authentication controls
- Restricted patient resources
- Historical web-accessible resources
- Exposed database backup and sensitive data stores

Out of Scope

- Social engineering
- Denial-of-service testing
- Systems outside the agreed target
- Unauthorised access to unrelated systems

2.2 Rules of Engagement

- Target domain only
- No social engineering
- No denial-of-service testing
- Written authorisation provided for the educational engagement

2.3 Methodology

Reconnaissance → Attack Surface Identification → Authentication Analysis → Vulnerability Identification → Controlled Exploitation → Restricted Resource Access → Data Extraction → Sensitive Data Exposure Analysis → Risk Assessment → Remediation

2.4 Tools & Techniques

Tool / Technique	Purpose
curl	HTTP requests, response inspection and resource validation
Python / pypdf	PDF analysis and document processing
John the Ripper wordlists	Dictionary-based password recovery testing
Manual SQL injection testing	Authentication input validation
Standard Linux utilities	File, metadata and evidence analysis

3. Assessment Attack Chain

The findings form a connected attack path. The sequence below summarises the demonstrated impact while avoiding unnecessary disclosure of confidential records.

Unauthenticated Web Access ↓ Patient Portal Login ↓ SQL Injection ↓ Authentication Bypass ↓ Restricted Patient Portal ↓ Three Encrypted Laboratory Reports ↓ PDF Password Recovery ↓ Medical Contents Accessible ↓ Sensitive PDF Metadata ↓ /old/ Directory Listing ↓ Public SQL Database Backup ↓ Staff & Shareholder Data Exposure

Milestone Completion

Milestone	Outcome	Status
M1	Authentication bypass and retrieval of three confidential encrypted laboratory reports	COMPLETED
M2	PDF password recovery, decryption and access to protected contents	COMPLETED
M3	Public database backup discovery and sensitive data exposure	COMPLETED
M4	Final security report, risk assessment and remediation plan	COMPLETED

4. Findings & Proof of Exploitation

The final assessment identified five findings ranging from Medium to Critical severity. The evidence below is intentionally sanitised for public-safe presentation.

F-001 — SQL Injection — Patient Portal Authentication Bypass

Attribute	Assessment Detail
Severity	Critical
Location / Asset	POST /patient/login.php — username parameter
Description	The login endpoint directly concatenated user input into SQL without adequate parameterisation or sanitisation. Error-based SQL injection was confirmed and authentication could be bypassed.
Proof / Evidence	A controlled test caused an HTTP 302 redirect to /patient/portal.php, establishing an authenticated session. Three confidential encrypted laboratory reports were then listed and downloaded.

Recommended Remediation

- Use parameterised queries / prepared statements.
- Validate and constrain user input.
- Review authentication and data-access code.
- Retest the authentication control after remediation.

F-002 — Weak PDF Encryption Passwords

Attribute	Assessment Detail
Severity	High
Location / Asset	Three laboratory-report PDFs retrieved during M1
Description	The reports used Adobe Standard security with RC4 128-bit encryption. Dictionary-based password-recovery testing successfully recovered the password for all three files.
Proof / Evidence	All three reports were decrypted and their protected contents became accessible. Actual recovered passwords are redacted from this report.

Recommended Remediation

- Replace weak passwords.
- Re-encrypt affected documents.
- Use strong random secrets or centralised authenticated access controls.
- Review document-sharing procedures.

Sensitive evidence is intentionally redacted from the public-facing report.

F-003 — Sensitive Database Backup Exposure

Attribute	Assessment Detail
Severity	Critical
Location / Asset	/old/mediroza_db_backup_2019.sql
Description	A historical SQL database backup was publicly accessible without authentication. The assessment reported 30 employee records and 10 shareholder records containing sensitive personnel, payroll and ownership information.
Proof / Evidence	The raw database dump was retained as authorised evidence. No employee names, national IDs, contact details, salary values or shareholder records are reproduced here.

Recommended Remediation

- Remove the backup from the web root.
- Restrict backups to authenticated administrative channels.
- Encrypt backups at rest.
- Review logs and search for additional exposed backups.

Sensitive evidence is intentionally redacted from the public-facing report.

F-004 — Directory Listing — /old/

Attribute	Assessment Detail
Severity	High
Location / Asset	/old/
Description	The directory returned an autoindex listing, making historical application resources and the database backup immediately discoverable.
Proof / Evidence	Directory indexing removed the need for blind resource discovery and materially assisted identification of the exposed backup.

Recommended Remediation

- Disable directory listing.
- Remove obsolete artifacts.
- Restrict historical resources.
- Apply a secure web-server configuration baseline.

F-005 — Sensitive PDF Metadata

Attribute	Assessment Detail
Severity	Medium
Location / Asset	Metadata associated with a recovered PDF
Description	Metadata disclosed internal usernames, migration comments, tool names and operational file-path information.
Proof / Evidence	The metadata information assisted further discovery of the historical backup location and exposed internal deployment context.

Recommended Remediation

- Sanitise document metadata before external distribution.
- Remove unnecessary comments and creator fields.
- Include metadata review in release and security testing.

5. Risk Rating & Prioritisation

The assessment uses a qualitative Critical / High / Medium / Low scale based on likelihood of exploitation and potential business impact, including confidentiality, regulatory exposure, reputational harm and financial loss.

Finding	Likelihood	Impact	Risk
SQL Injection — Patient Portal	High — trivial payload	Critical — patient data access	Critical
Exposed HR / Shareholder DB Backup	High — public URL	Critical — payroll & ownership data	Critical
Weak PDF Passwords	High — dictionary recoverable	High — medical results exposed	High
Directory Listing /old/	High	High — enables discovery	High
Sensitive PDF Metadata	Medium	Medium — aids attackers	Medium

Overall Organisational Risk: CRITICAL

The two independent Critical findings require immediate executive attention and prioritised remediation.

6. Recommendations & Remediation

6.1 Immediate — Critical | 24–48 Hours

- 1 Fix SQL injection using parameterised queries / prepared statements; validate input and use WAF rules only as a temporary compensating control.
- 2 Remove the exposed database backup from the web root and disable directory listing.
- 3 Rotate potentially affected credentials and review relevant access logs.

6.2 Short-Term — High Priority | 1–2 Weeks

- 1 Strengthen document encryption and re-secure affected patient reports.
- 2 Strip sensitive PDF metadata before external distribution.
- 3 Store database and configuration backups outside the web root, encrypted and access-controlled.

6.3 Medium-Term — Hardening

- 1 Conduct a full source-code review of authentication and data-access layers.
- 2 Implement proper session management, account lockout and MFA for patient and staff portals.
- 3 Establish a secure development lifecycle with dependency scanning, static analysis and periodic external testing.
- 4 Review POPIA and other applicable privacy obligations.

Remediation Tracking Matrix

Priority	Action	Target
P0	Remediate SQL injection	24–48 hours
P0	Remove database backup	24–48 hours
P0	Disable /old/ directory listing	24–48 hours
P1	Re-secure affected reports and metadata	1–2 weeks
P1	Secure backup architecture	1–2 weeks
P2	SDL, MFA, source review and recurring testing	Medium-term

7. Final Conclusion & Week 4 Status

The penetration test demonstrated multiple security weaknesses affecting authentication, confidentiality, document protection and sensitive data storage. The most consequential issues were authentication bypass through SQL injection and public exposure of a sensitive database backup.

The combined weaknesses created a significant confidentiality risk affecting patient information, personnel data, payroll information and shareholder ownership data. Critical findings should be remediated before production use, followed by validation testing.

Week 4 Completion

Milestone	Required Outcome	Status
M1	Initial Access & Patient Report Retrieval	COMPLETED
M2	PDF Encryption Recovery & Data Extraction	COMPLETED
M3	Critical Data Exposure	COMPLETED
M4	Final Penetration Testing Report	COMPLETED

FINAL STATUS: ALL WEEK 4 MILESTONES COMPLETED

Authorisation & Responsible Use

This assessment was performed as part of the authorised Mediroza General Hospital educational engagement. The techniques documented are intended solely for authorised security testing, validation, learning and remediation. No testing should be performed against systems without prior written permission from the system owner.

Appendix A — Public-Safe Evidence Handling

Do not publish unredacted patient laboratory reports, recovered passwords, raw SQL dumps, employee personal identifiers, individual salary values or complete shareholder registers.

Suitable public evidence includes redacted screenshots, sanitised identifiers, HTTP status evidence without secrets, finding summaries, severity ratings, remediation guidance and synthetic or redacted database schemas.

This report is based on the supplied Week 4 final penetration-testing report. The supplied source establishes the engagement details, methodology, five findings, proof of exploitation, risk ratings and remediation recommendations. This version redesigns that material into a professional submission format and removes unnecessary sensitive disclosure.

END OF REPORT